AI Hacking Agent

Teaching an AI to Find Website Security Holes

Capstone Project Report

An AI that learns, by trial and error, to break into a practice website — and beats random guessing six to one. Safe, practice-only.

RL · RLcapstone.ai

1. Summary

I built a tiny fake website with three security holes on purpose, then built an AI that learns to find all three — by trial and error, the same way game-playing AIs learn. Once trained, it finds every hole in just **4 moves**. Random guessing takes about **25** and usually misses one.

> This is educational and totally sandboxed. Everything runs on a fake website on my own computer. These are standard practice-hacking examples (the OWASP Top 10), and you should only ever try this stuff on systems you own or are allowed to test.

2. Why I built this

Normal security scanners are fast but kind of dumb — they follow a fixed script and can't adapt. I read that a type of AI called **reinforcement learning** can learn smart attack paths, so I wanted to try it at a size I could actually understand and explain.

3. The practice website

The target is a tiny fake 'bank' website (about 120 lines of code) running on my computer, with three classic holes on purpose:

- SQL injection — you can log in without a password by typing a trick into the username box.
- XSS — the search box will actually run code you type into it.
- Broken access control — changing a number in the web address lets you see someone else's private info.

4. How it works

I turned hacking into a simple game. The AI can pick from 12 possible moves (look around, try each attack, plus some dead-end moves that just waste time). Every move is a **real request** to the website, and it only scores when the website actually gives up a secret.

It learns with something called **Q-learning** — basically a scorecard of how good each move is. It gets +10 for finding a new hole, +2 for looking around first, and –1 for every move, so shorter attacks win. Nobody tells it which moves are good; it figures that out on its own.

5. Results

Agent	Moves to find all 3	Found all 3
Trained AI	4	100% of the time
Random guessing	about 25	only 50% of the time

Over a few hundred practice runs, the AI goes from flailing around (a big negative score) to a clean four-move attack: look around, then one perfect move for each hole. It ends up about **six times faster** than random guessing. When it's done, it even writes up a little security report of what it found and how to fix each hole.

6. Honest limitations

- It's a tiny practice setup — three known holes and twelve moves — so it's a learning demo, not a real hacking tool.
- It only ever touches a fake website on my own computer, using standard practice examples.
- It's meant purely for learning and defense — understanding how attacks work so you can stop them.

7. What's next

- Add more kinds of holes and a second practice site to see if it can adapt to something new.
- Hook up a language model to write better reports.
- Compare it against regular scanner tools.